

A S D

Australian Signals Directorate

Australian Information Security Manual

I S M

Controls · Guidelines · Security Lifecycle · Incident Response

"The ISM helps organisations protect their systems and data against cyber threats using a risk-based, control-driven approach." — Australian Signals Directorate

WHAT'S INSIDE

ISM Overview

Governance & Risk

Security Controls

System Hardening

Access & Auth

Cryptography

Incident Response

E8 Alignment

What is the ISM?

ISM Overview — Australian Signals Directorate (ASD)

- Published by the Australian Signals Directorate (ASD)
- Risk-based framework for protecting government & critical systems
- Provides controls, guidelines & principles for information security
- Updated continuously — controls aligned to the current threat landscape
- Mandatory for Commonwealth entities — recommended for all organisations

■ Purpose

- Risk-based security approach
- Protect systems and data
- Reduce cyber threat exposure
- Align all ICT to ASD guidance
- Support whole-of-govt policy

■ Who Uses It?

- All Commonwealth agencies
- Critical infrastructure operators
- Defence industry contractors
- State/territory governments
- Private sector by adoption

■ What It Covers

- Governance & risk management
- Security controls by tier
- System & network hardening
- Access control & cryptography
- Incident response & recovery

ISM DOCUMENT STRUCTURE

PRINCIPLES

High-level statements governing the entire information security strategy

GUIDELINES

Contextual guidance — explains WHY and HOW controls are correctly implemented

CONTROLS

Specific, measurable requirements applied to systems, people and processes

ASSESSMENT

Method to evaluate effectiveness and maturity of controls across all systems

ISM AT A GLANCE — KEY FACTS

Published by: Australian Signals Directorate (ASD) — updated regularly at asd.gov.au

Applies to: All entities under the Australian Govt Protective Security Policy Framework

Core document: Fully searchable control database freely available at asd.gov.au/ism

Control count: 900+ individual controls across all domains — risk-based selection applies

EXAMPLE:

A federal Department of Home Affairs must classify all data assets, select applicable ISM controls by sensitivity tier, evidence compliance to the Authorising Officer, and re-assess annually. Non-compliance escalates to the Australian Cyber Security Centre.

Governance & Risk Management

ISM Governance — Roles · Lifecycle · Risk Categories · Principles

Chief Information Security Officer (CISO)	System Owner	Security Assessor	Authorising Officer (AO)
Owns org-wide security posture & ISM compliance plan	Accountable for their assigned systems and controls	Reviews control gaps tests effectiveness & flags issues	Formally approves system operation based on risk review

ISM SECURITY LIFECYCLE

1	2	3	4	5
DEFINE	ASSESS	TREAT	AUTHORISE	MONITOR
Identify & classify all assets and system boundaries	Identify threats, vulnerabilities & business impact	Apply ISM controls scaled to data classification tier	AO formally approves system operation based on evidence	Continuous review, re-assessment & control improvement

RISK MANAGEMENT CATEGORIES

Confidentiality Risk

Unauthorised access to classified or sensitive government data by any party

Integrity Risk

Tampering with, corruption of, or falsification of critical system data

Availability Risk

Disruption to critical services through denial-of-service or ransomware

Compliance Risk

Failure to meet ISM obligations, PSPF requirements or regulatory duties

GOVERNANCE PRINCIPLES — ISM CHAPTER 2

Accountability

System Owners are personally accountable for security of their systems

Risk Acceptance

The AO accepts residual risk — not the CISO or the technical team

Proportionality

Controls applied proportional to the classification and sensitivity of data

Transparency

All security decisions, exceptions and waivers must be fully documented

EXAMPLE:

An Authorising Officer reviews a new HR system. The CISO presents a risk treatment plan showing all Tier 1 ISM controls implemented and residual risks documented. The AO formally authorises system operation for 12 months before a mandatory reassessment is scheduled.

Information Security Controls

ISM Control Categories — Physical · Personnel · ICT Systems

PHYSICAL SECURITY	PERSONNEL SECURITY	ICT SYSTEM CONTROLS
■ Facility access Control server room entry via badges ■ Clean desk policy No sensitive data left unattended ■ Secure media disposal Degauss or shred all physical media ■ Visitor management Log and escort all visitors always ■ CCTV & alarms Surveillance at sensitive facilities	■ Security clearances Required for all classified access ■ Pre-employment checks Background & criminal history checks ■ Security awareness Mandatory annual security training ■ Least privilege Minimum access for each role only ■ Separation of duties Split all critical functions	■ System hardening Remove all unnecessary features ■ Patch management Deploy patches within SLA timeframes ■ Logging & auditing Retain all logs for 7+ years minimum ■ Vulnerability scans Scan & remediate CVEs regularly ■ Config baseline Hardened configs deployed, deviations alerted

ISM DATA CLASSIFICATION TIERS

Tier	Classification	Controls Required	Sensitivity
1	UNOFFICIAL	No formal controls — general public information only	Low
2	OFFICIAL	Standard baseline controls for day-to-day government	Medium
3	OFFICIAL: Sensitive	Enhanced controls — encryption at rest mandatory	High
4	PROTECTED	Strict access — MFA, audit logging, encryption on	Very High
5	SECRET / TOP SECRET	Air-gapped systems — compartmented access only	Critical

CONTROL SELECTION GUIDANCE

Step 1 — Classify	Determine classification tier for each system and data asset in scope
Step 2 — Select	Choose applicable ISM controls from the relevant chapter for that tier
Step 3 — Implement	Apply controls with documented evidence — both technical and procedural
Step 4 — Evidence	Collect and retain compliance evidence for the Authorising Officer review

EXAMPLE:

A Department of Home Affairs employee handles OFFICIAL: Sensitive immigration records.
Controls applied: encrypted laptops, MFA enforced, clean-desk policy, access events logged, patches applied within 2 weeks, records reviewed by the CISO on a quarterly basis.

System Hardening & Network Security

ISM Guidelines — Configurations · Network Architecture · Endpoint Controls

OS HARDENING CONTROLS

- **Remove unneeded services**
Disable services not required for function
- **Host-based firewall**
Default-deny — block all inbound traffic
- **Application allowlisting**
Only approved, signed apps execute
- **Automated OS patching**
Critical patches within 48 hours — ML 3
- **Disable autorun/autoplay**
Block malware via USB on all systems
- **Rename default accounts**
Rename defaults, rotate all passwords
- **Enable audit logging**
All events shipped to centralised SIEM

NETWORK SECURITY CONTROLS

- **Network segmentation**
Separate networks via VLANs and ACLs
- **Perimeter firewalls**
Block all traffic — log all allow rules
- **IDS / IPS deployment**
Detection & prevention at all boundaries
- **TLS 1.3 for all comms**
TLS 1.2 minimum — HTTP strictly blocked
- **DNS filtering**
Block malicious domains at DNS layer
- **Email gateway controls**
SPF, DKIM, DMARC — sandbox all attachments
- **Zero Trust architecture**
No implicit trust — verify all users

ENDPOINT HARDENING QUICK CHECKLIST

- ✓ Disk encryption enabled (BitLocker / FileVault) on all endpoints
- ✓ Screen lock set to 5 minutes idle maximum on all workstations
- ✓ Local admin renamed, strong password and MFA enforced
- ✓ USB ports disabled or allowlisted via Group Policy
- ✓ Antivirus / EDR agent deployed and centrally managed
- ✗ Guest and shared accounts disabled and removed from all systems
- ✗ Unnecessary browser plugins and extensions removed
- ✗ End-of-life OS versions fully removed from production

RECOMMENDED NETWORK SECURITY ZONES

INTERNET	DMZ	CORPORATE LAN	CLASSIFIED
Untrusted zone — all traffic filtered via perimeter FW	Web & app servers, external-facing services hosted here	Standard users, workstations & internal services	Sensitive systems — air-gapped or strictly segmented

EXAMPLE:

A government agency deploys classified HR systems in an isolated VLAN with no internet. All workstations hardened via Group Policy — USB blocked, BitLocker on, local admin removed. IDS monitors east-west traffic. Patch compliance verified weekly via vulnerability scanner.

Access Control & Cryptography

ISM Guidelines — Authentication · Authorisation · Data Protection

ACCESS CONTROL

- **Least Privilege**
Grant minimum access — quarterly reviews
- **Role-Based Access (RBAC)**
Permissions tied to role, not individuals
- **Privileged Access Mgmt**
Separate admin accounts — PAM enforces JIT
- **Account Lifecycle**
Disable accounts on role change or departure
- **Session Timeout**
Auto-lock after 15 min idle — all systems
- **Single Sign-On (SSO)**
Centralised identity — reduces sprawl risk
- **No Shared Accounts**
Every user requires a unique identity always

CRYPTOGRAPHY

- **AES-256 at Rest**
AES-256 mandatory for PROTECTED and above
- **TLS 1.3 in Transit**
TLS 1.2 minimum — TLS 1.3 preferred
- **PKI & Certificates**
PKI for auth — certs via central CA
- **Key Management**
Keys rotated annually — HSMs for critical
- **SHA-256+ Hashing**
SHA-256 only — MD5 and SHA-1 are banned
- **Full Disk Encryption**
BitLocker or equivalent on all laptops
- **Email Encryption**
S/MIME or PGP — mandatory above OFFICIAL

ISM MFA REQUIREMENTS BY SYSTEM TYPE

System Type	MFA Required?	Recommended Method
Internet-facing services & portals	Mandatory	FIDO2 hardware key or TOTP app
VPN & all remote access sessions	Mandatory	Certificate + PIN or push MFA
PROTECTED / SECRET systems	Mandatory	Phishing-resistant FIDO2 only
Internal corporate systems	Strongly Advised	Microsoft or Google Authenticator
Low-risk internal read-only tools	Recommended	Password + email OTP minimum

APPROVED CRYPTOGRAPHIC ALGORITHM REFERENCE

APPROVED	AES-256 · RSA-2048+ · ECC-256+ · SHA-256 · SHA-512 · TLS 1.3 · PBKDF2
BANNED	DES · 3DES · RC4 · MD5 · SHA-1 · SSL 2.0 · SSL 3.0 · TLS 1.0 · TLS 1.1

EXAMPLE:

A Defence contractor accesses a PROTECTED portal. ISM mandates FIDO2 hardware MFA, AES-256 at rest, TLS 1.3 in transit, and a separate admin account for elevated tasks. Sessions expire after 15 min idle. All access events are logged and retained for 7 years.

Incident Response & Recovery

ISM Guidelines — Detect · Contain · Eradicate · Recover · Learn

ISM INCIDENT RESPONSE LIFECYCLE

1	2	3	4	5
DETECT	CONTAIN	ERADICATE	RECOVER	LESSONS
Monitor SIEM alerts IDS/IPS 24x7x365 & endpoint events	Isolate affected systems immediately stop lateral spread	Remove malware, close exploit path & patch root cause	Restore from clean validated backups verify data integrity	Post-incident review update all controls & playbooks always

ASD CYBER INCIDENT REPORTING OBLIGATIONS

Category	Severity	Notify By	Description
CAT 1	Critical	Within 1 hour	Compromised classified system or critical national infrastructure
CAT 2	High	Within 4 hours	Significant data breach or ransomware on sensitive systems
CAT 3	Medium	Within 24 hours	Unauthorised access found — no confirmed data exfiltration
CAT 4	Low	Within 72 hours	Policy violation detected — no confirmed breach identified

KEY ROLES DURING A CYBER INCIDENT

Incident Commander	Leads entire response — coordinates all teams, decisions and comms
CISO	Approves containment strategy, scope changes and ASD escalation
SOC Analyst	Monitors SIEM, triages all alerts, collects forensic evidence
Legal / Privacy	Advises on breach notification duties to OAIC and individuals

INCIDENT RESPONSE PLAYBOOK ESSENTIALS

Preparation	Documented IR plan, contact lists and pre-approved isolation procedures
Communication	Internal comms chain defined — external: ASD, OAIC, affected individuals
Forensics	Preserve all evidence before containment — chain of custody documented
Post-Incident	Written review within 30 days — findings update policies and controls

EXAMPLE:

Friday 11pm — SIEM alert: ransomware detected spreading across agency file servers. Incident Commander isolates the VLAN. SOC confirms no spread to the classified LAN. CISO notifies ASD (CAT 2) within 4 hours. IT restores from offline backup by morning.

ISM & Essential Eight Alignment

How ISM Controls Directly Map to the ACSC Essential Eight Strategies

ISM CONTROLS MAPPED TO ESSENTIAL EIGHT STRATEGIES

E8 Strategy	ISM Controls	ISM Guidance	Maturity
1. Patch Applications	ISM-0300-0304	Apps patched within SLAs — internet first	ML 1-3
2. Patch Operating Systems	ISM-1690-1695	OS patches 48hrs at ML3 — EOL removed	ML 1-3
3. Multi-Factor Auth	ISM-1173-1175	MFA mandatory for remote & privileged access	ML 1-3
4. Restrict Admin Privs	ISM-1507-1509	Least privilege, JIT via PAM, PAWs enforced	ML 1-3
5. Application Control	ISM-0140-0142	Allowlisting — unapproved executables blocked	ML 1-3
6. Restrict Office Macros	ISM-1800-1805	Unsigned macros blocked — signing required	ML 1-3
7. User App Hardening	ISM-1480-1485	Browsers/Office hardened via GPO, web filter	ML 1-3
8. Regular Backups	ISM-1511-1515	Backups isolated from network — 3-2-1 rule	ML 1-3

ISM MATURITY ASSESSMENT MODEL

LEVEL 1 — INITIAL	Ad-hoc, undocumented controls — organisation is fully exposed to cyber risk
LEVEL 2 — DEVELOPING	Some controls in place — inconsistently applied or incomplete across systems
LEVEL 3 — MANAGING	Controls documented and consistently applied across all systems in scope
LEVEL 4 — OPTIMISING	Continuous improvement — controls fully automated and continuously measured

QUICK COMPARISON: ISM · GDPR · Australian Privacy Principles

Aspect	ISM (ASD)	GDPR (EU)	APP / Australia
Primary Focus	Cyber security controls	Data privacy rights	Privacy obligations
Enforcing Body	ASD / ACSC	DPA / ICO	OAIC
Breach Notice	ASD Category 1-4	72hrs to Supervisory	NDB Scheme — OAIC
Max Penalty	Operational/reputational	EUR 20M or 4% revenue	AUD \$50M corporate
Key Document	ISM at asd.gov.au	GDPR Articles 5 & 83	Privacy Act 1988 Cth

EXAMPLE:

An organisation achieving ML 3 across all E8 strategies satisfies the majority of ISM controls for OFFICIAL: Sensitive — forming a complete, evidence-based posture that simultaneously satisfies ASD, OAIC and Australian privacy law obligations.

Key Takeaways

ISM Summary — Core Flow · Quick Reference · Principles · Author

ISM CORE SECURITY FLOW

IDENTIFY	PROTECT	DETECT	RESPOND	RECOVER
Classify assets & define system boundaries first	Apply ISM controls scaled to data classification tier	Monitor via SIEM, logs, IDS/IPS & vulnerability scans	Incident playbooks, ASD notification & containment	Restore from clean backups — lessons learned always

ISM STUDY NOTES — COMPLETE QUICK REFERENCE

ISM Overview — Risk-based framework | ASD | Principles · Guidelines · 900+ Controls

Governance & Roles — CISO · System Owner · Authorising Officer · Security Assessor

Security Lifecycle — Define → Assess → Treat → Authorise → Monitor (annual cycle)

Control Categories — Physical · Personnel · ICT — Unofficial through SECRET classification

System Hardening — OS hardening · Network zones · Endpoint checklist · Config baseline

Access & Cryptography — Least privilege · MFA · AES-256 · TLS 1.3 · PKI · Key management

Incident Response — Detect → Contain → Eradicate → Recover → Lessons (ASD CAT 1-4)

E8 & ISM Alignment — All 8 strategies mapped to ISM control numbers — ML 1 to ML 3

CORE PRINCIPLES TO REMEMBER

- Risk-based, not rules-based — controls must always scale to the data classification level
- Classify all assets first — every ISM control decision flows directly from classification
- ISM + Essential Eight together form a complete defence-in-depth cyber security strategy
- Continuous monitoring is mandatory — ISM compliance is an ongoing obligation, not once-off

Thanks for Reading!

Save for reference · Share with your network · Apply the ISM in your organisation!

YG

Yadav Ghorasainee

linkedin.com/in/yadav-ghorasainee | yadavcybernet.github.io/sec/

Information Security Professional · ISM · GDPR · APP · Essential Eight